

Simulación de ataque informático y remediación

1. Directrices del proyecto:

- Equipos de trabajo: 6 personas.
- Entorno de Ejecución: el proyecto debe correr en un entorno de máquinas virtuales (Virtual Box). Se requiere como mínimo una VM Atacante (Kali Linux) y una VM Víctima (servidor con el código desarrollado).
- Repositorio GitHub: el código debe estar publicado con acceso total al profesor. Se evaluará la autoría mediante el historial de commits (aportes individuales de los participantes en el equipo de trabajo). El repositorio debe contener dos ramas o carpetas claramente diferenciadas: versión-vulnerable y versión-asegurada. Cada bloque de código vulnerable debe incluir comentarios manuales que expliquen por qué esa línea específica es insegura y qué función de biblioteca o lógica de control falta.
- Metodología:
 - Se va a evaluar el seguimiento y cumplimiento de lo establecido en OWASP, tanto en el comportamiento del riesgo como en la prevención o aseguramiento.
- Es obligatorio mapear el ciclo de vida del ataque utilizando uno de los siguientes marcos de trabajo: Cyber Kill Chain o MITRE ATT&CK®.
- Queda estrictamente prohibido el uso de librerías, frameworks o configuraciones que automaticen la seguridad. Toda funcionalidad (procesamiento de consultas, gestión de archivos, autenticación o consumo de recursos externos) debe construirse mediante lógica manual. Se debe utilizar la manipulación o concatenación directa de variables suministradas por el usuario sin procesos intermedios de limpieza. El código debe estar diseñado de forma que permita evidenciar, tanto visual como técnicamente, cómo la ausencia de validación, aseguramiento o controles de acceso rompe la integridad, confidencialidad o disponibilidad del sistema. Los alumnos deben ser capaces de explicar la ruta exacta que sigue el código malicioso (payload) desde el punto de entrada (interfaz de usuario o API) hasta el punto de ejecución final donde se materializa el ataque. El equipo debe justificar por qué la lógica implementada es vulnerable bajo los estándares de OWASP correspondientes, demostrando que comprenden el fallo estructural del código.
- Para la primera entrega del proyecto se va a seleccionar al azar a un equipo de proyecto, el cual presencialmente tendrá que justificar lo expuesto en el Anteproyecto entregado.

2. Alcance del proyecto:

La aplicación debe ser vulnerable y atacada exitosamente bajo al menos dos riesgos de seguridad de acuerdo a la siguiente tabla (deben seleccionar uno con ID 1 y uno con ID 2):

Riesgos de seguridad	Alcance mínimo de codificación (lo que deben programar)	Objetivo del Atacante	ID
Ruptura de Autenticación – Aplicaciones web (A01:2025 - Broken Access Control)	Por ejemplo: programar un módulo de gestión de acceso donde el control de acceso a recursos privados dependa de parámetros del lado del cliente (ID en URL, cookies, etc.) sin validación en el servidor.	Suplantar identidades o acceder a datos de terceros.	1
Inyección – Aplicaciones web (A05:2025 Injection)	Por ejemplo: implementar un módulo de procesamiento de datos que acepte entradas del usuario sin procesos de aseguramiento o validación previa.	Alterar la lógica de ejecución del servidor para extraer datos o tomar control del sistema.	1
Gestión Deficiente de Condiciones de Excepción – Aplicaciones web (A10:2025 Mishandling of Exceptional Conditions)	Por ejemplo: desarrollar un módulo de sistema que cuente con una lógica de manejo de errores que, ante fallos del sistema, exponga detalles técnicos internos en la respuesta al cliente.	Recolectar información sobre la infraestructura y arquitectura para facilitar ataques dirigidos.	2
Consumo No Seguro de APIs (API10:2023 Unsafe Consumption of APIs)	Por ejemplo: crear una integración con un servicio externo que procese la información recibida bajo una relación de confianza ciega, sin validación de integridad.	Injectar contenido malicioso a través de un canal que el sistema considera seguro por defecto.	1
Fallas Criptográficas – Aplicaciones web (A04:2025 Cryptographic Failures)	Por ejemplo: implementar funciones de protección de datos basadas en algoritmos débiles, obsoletos o con una gestión de llaves insegura.	Descifrar información sensible en reposo o interceptar comunicaciones privadas en tránsito.	2

SSRF API (API7:2023 - Server Side Request Forgery (SSRF))	Por ejemplo: programar un endpoint que realice peticiones externas basadas en URLs suministradas por el usuario sin aplicar una lista de destinos permitidos.	Manipular al servidor para que actúe como un proxy y escanee o ataque la red interna protegida.	2
Seguridad inadecuada en la cadena de suministro en Móviles (M2: Inadequate Supply Chain Security)	Por ejemplo: construir una aplicación móvil que dependa de componentes o librerías de terceros que presenten vulnerabilidades conocidas o código malicioso.	Comprometer la integridad de la aplicación final mediante la explotación de sus dependencias.	2
Ingeniería Inversa en Móviles (M7: Insufficient Binary Protections)	Por ejemplo: desarrollar un binario móvil que carezca de mecanismos de protección y ofuscación, dejando expuesta la lógica crítica de negocio.	Analizar el binario para extraer secretos, entender protocolos privados o modificar el comportamiento de la app.	1

3.- Entregas

Entrega 1: Anteproyecto y modelado de amenazas

Esta etapa es de planificación técnica. Se hace entrega a través de un informe del mapa o la arquitectura del proyecto. Debe contener:

- Arquitectura de la aplicación: diagrama de componentes y tecnologías.
- Superficie de ataque: identificación precisa de los puntos de entrada. Identificación de los puntos donde se explotarán los 2 riegos obligatorios.
- Identificación y detalles de las vulnerabilidades a explotar.
- Identificación y detalles de las contramedidas a implementar
- Configuración del laboratorio: descripción de las máquinas virtuales (Kali, servidores, etc.) y red.
- Identificar los CWE mapeados. Identificación de los Common Weakness Enumeration (CWE) asociados a las vulnerabilidades.
- Identificación de la metodología seleccionada. Diagrama de la arquitectura y mapeo del ataque usando la metodología que corresponda. Pasos del ataque siguiendo Cyber Kill Chain o MITRE ATT&CK®.
- Organización del equipo de trabajo. Alumnos asignados al Red Team y alumnos asignados al Blue Team.
- Luego de la entrega vía módulo 7 se va a seleccionar al azar a un equipo de proyecto, el cual presencialmente tendrá que justificar lo expuesto en el Anteproyecto entregado.

Etapa 2: Demostración y defensa oral

Esta etapa es de entrega final de resultados. Se lleva a cabo la demostración técnica del ataque y su remediación. Se lleva a cabo una presentación oral con los aspectos técnicos relacionados al proyecto la cual debe contener:

- Demo ofensiva: ejecución en tiempo real del ataque. Explicación del código vulnerable desarrollado.
- Demo defensiva: implementación de las medidas correctivas (parches de código, firewalls, aseguramiento del código, etc.). Explicación de las medidas implementadas y demostración de la ineficacia del ataque tras la remediación.
- Análisis de impacto: explicación técnica de qué ocurrió a nivel de memoria/red/base de datos/servidor/etc..
- Demostración de la metodología empleada. Deben documentar su proceso y explicarlo paso a paso.
- Readme técnico: manual de despliegue y descripción del stack tecnológico en github.

- Inventario de endpoints: listado de rutas de la API o formularios que serán el blanco de la Inyección, ruptura de autenticación, etc..
- Diagrama de flujo de datos: marcando específicamente dónde se rompe la seguridad (por ejemplo: puntos de inyección).
- Prueba de conectividad: pantallas o logs de red que demuestren que la máquina atacante (Kali) tiene visibilidad y alcance técnico sobre la aplicación víctima en el entorno virtual.
- Deben entregar un documento de texto o script .sh con los payloads, por ejemplo códigos de inyección o scripts maliciosos empleados.
- Validación de cierre. Demostrar que el exploit ya no funciona y explicar el cambio técnico (ej: uso de consultas preparadas, validación de permisos, etc.).
- Acciones sobre objetivos. Que impacto tuvo el ataque (robo de datos, control del servidor, etc.).